

Lezione — Modulo D8: Privacy e Protezione dei Dati Personali

Corso: Diritto dell'Informatica T

Materiale: 08_DirInfo_2026_Privacy_DEF.pdf (63 slide, prof. Claudia Cevenini)

Normative di riferimento: Reg. UE 2016/679 (GDPR), D.Lgs. 196/2003 s.m.i. (Codice Privacy)

Obiettivo

Saper spiegare l'intera disciplina della protezione dei dati personali: ambito di applicazione del GDPR, definizioni fondamentali, soggetti coinvolti, principi e basi giuridiche del trattamento, obblighi del titolare, diritti dell'interessato, misure di sicurezza, violazioni, DPIA, DPO, trasferimenti extra UE e sanzioni.

§1 — Norme di Riferimento

[fonte: PDF p. 2]

Il quadro normativo di riferimento è composto da due fonti principali:

Reg. UE 2016/679 — detto GDPR (*General Data Protection Regulation*). È in vigore dal 25 maggio 2016 e **si applica direttamente** in tutti gli Stati Membri dell'UE dal **25 maggio 2018**. Lascia un **marginale di autonomia** agli Stati Membri su determinati ambiti.

D.Lgs. 196/2003 — detto Codice Privacy. È stato **aggiornato a settembre 2018** per adeguarlo al Regolamento.

Attenzione: il Regolamento non è l'unica fonte a cui attenersi. Si devono rispettare anche il Codice Privacy aggiornato e ogni altra normativa pertinente (es. Statuto dei lavoratori). Occorre tenere conto delle Linee Guida del Comitato Europeo per la Protezione dei Dati e dei Provvedimenti del Garante. [fonte: PDF p. 59]

§2 — Cosa Tutela il Regolamento

[fonte: PDF p. 3]

Il Regolamento **protegge i diritti e le libertà fondamentali delle persone fisiche**, in particolare il **diritto alla protezione dei dati personali**. Tale diritto deve essere garantito a **chiunque**.

Il GDPR si applica ai trattamenti di dati personali delle **persone fisiche** (=individui) e **NON** delle persone giuridiche (=società, enti e associazioni).

NON si applica ai **dati anonimi**, da cui sia impossibile identificare una persona.

§3 — Ambito di Applicazione Materiale

[fonte: PDF p. 4]

Il Regolamento **si applica** al trattamento di dati personali: - interamente o parzialmente **automatizzato**, e - **non automatizzato** di dati personali contenuti in un archivio o destinati a figurarvi.

Il Regolamento **non si applica** al trattamento effettuato: - da **persone fisiche** per l'esercizio di **attività esclusivamente personali o domestiche**; - dalle **autorità competenti** a fini di prevenzione, indagine, accertamento o perseguimento di **reati** o esecuzione di **sanzioni penali**, salvaguardia contro minacce alla **sicurezza pubblica** e la prevenzione delle stesse.

§4 — Ambito di Applicazione Territoriale

[fonte: PDF p. 5]

Il Regolamento si applica al trattamento di dati personali:

1. effettuato da **titolare o responsabile stabilito nell'UE**, indipendentemente dal luogo di trattamento dei dati;
 2. effettuato da **titolare o responsabile non stabilito nell'UE**, se riguarda **dati di interesse che si trovano nell'UE**, per:
 - l'offerta di beni o la prestazione di servizi, o
 - il monitoraggio del loro comportamento all'interno dell'UE.
-

§5 — Il Concetto di Dato Personale

[fonte: PDF p. 6]

«Qualsiasi informazione riguardante una persona fisica identificata o identificabile (=interessato); si considera identificabile la persona fisica che può essere identificata, direttamente o indirettamente, con particolare riferimento a un identificativo come il nome, un numero di identificazione, dati relativi all'ubicazione, un identificativo online o a uno o più elementi caratteristici della sua identità fisica, fisiologica, genetica, psichica, economica, culturale o sociale»

IMPORTANTE: I dati personali si distinguono in “comuni” e “sensibili” (= altre categorie di dati).

§6 — Il Concetto di Trattamento

[fonte: PDF p. 7]

«Qualsiasi operazione o insieme di operazioni, compiute con o senza l'ausilio di processi automatizzati e applicate a dati personali o insiemi di dati personali», come: raccolta, registrazione, organizzazione, strutturazione, conservazione, adattamento o modifica, estrazione, consultazione, uso, comunicazione mediante trasmissione, diffusione o qualsiasi altra forma di messa a disposizione, raffronto o interconnessione, limitazione, cancellazione o distruzione.

Attività specifiche di trattamento

[fonte: PDF p. 8]

Profilazione: qualsiasi forma di trattamento automatizzato di dati personali consistente nell'utilizzo di tali dati per valutare determinati aspetti personali relativi a una persona fisica, in particolare per analizzare o prevedere aspetti riguardanti il rendimento professionale, la situazione economica, la salute, le preferenze personali, gli interessi, l'affidabilità, il comportamento, l'ubicazione o gli spostamenti di detta persona fisica.

Pseudonimizzazione: il trattamento dei dati personali in modo tale che i dati personali non possano più essere attribuiti a un interessato specifico senza l'utilizzo di informazioni aggiuntive, a condizione che tali informazioni aggiuntive siano conservate separatamente e soggette a misure tecniche e organizzative intese a garantire che tali dati personali non siano attribuiti a una persona fisica identificata o identificabile.

§7 — I Soggetti Coinvolti nel Trattamento

[fonte: PDF pp. 9, 14, 17]

Titolare del trattamento

La persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che, **singolarmente o insieme ad altri, determina le finalità e i mezzi del trattamento** di dati personali.

Nota: il Titolare tratta dati per **PROPRIO conto** — es. una società che tratta i dati dei propri clienti e dipendenti.

Responsabile del trattamento

La persona fisica o giuridica, l'autorità pubblica, il servizio o altro organismo che **tratta dati personali per conto del titolare** del trattamento.

Es. consulente del lavoro che tratta dati dei dipendenti delle società per cui elabora le buste paga; call center che contatta i clienti dei propri committenti; fornitore di servizi cloud che tratta dati per conto dei propri clienti.

Il Responsabile: - deve fornire **garanzie sufficienti** per mettere in atto **misure tecniche e organizzative adeguate**; - può nominare a sua volta un **sub-responsabile solo** con **autorizzazione scritta**, specifica o generale, del titolare; - deve trattare i dati personali soltanto su **istruzione documentata** del titolare del trattamento.

ATTENZIONE: Non confondere il “**Responsabile del trattamento**” (= *data processor*) con il “**Responsabile della protezione dei dati**” (*Data Protection Officer*)!

Come è nominato il Responsabile del trattamento? Occorre un **contratto** o altro atto giuridico che vincoli il responsabile al titolare e che stipuli: la materia disciplinata, la durata del trattamento, la natura del trattamento, la finalità del trattamento, il tipo di dati personali, le categorie di interessati, gli obblighi e i diritti del titolare del trattamento.

Attenzione a non confondere il contratto di servizi (incarico/mandato professionale o termini e condizioni di servizio) e il contratto per il trattamento dei dati personali (questo).

Interessato

Persona fisica cui si riferiscono i dati personali. [es. utente, cliente, paziente]

Soggetto Autorizzato/Designato

Collaboratore o dipendente del Titolare o del Responsabile, che opera sotto la loro autorità. Il titolare o il responsabile individuano le modalità più opportune per autorizzare al trattamento le persone che operano sotto la propria autorità diretta. V. Codice Privacy, art. 2-*quaterdecies*.

§8 — Obblighi del Titolare del Trattamento

[fonte: PDF pp. 10-13]

Privacy by Design (Protezione dei dati fin dalla progettazione)

Il titolare del trattamento deve mettere in atto **misure tecniche e organizzative adeguate**, quali la pseudonimizzazione, allo scopo di: - attuare in modo efficace i principi di **protezione dei dati**, quali la **minimizzazione**; - integrare nel trattamento le necessarie **garanzie** al fine di soddisfare i **requisiti** del Regolamento e **tutelare** i diritti degli interessati.

Tale obbligo deve essere adempiuto: - sia **al momento di determinare i mezzi del trattamento**, - sia **all'atto del trattamento stesso**.

(Obbligo indicato anche come *data protection by design* o *privacy by design*) — **STUDIARE ART. 25 DEL REGOLAMENTO**

Privacy by Default (Protezione dei dati per impostazione predefinita)

Il titolare del trattamento deve mettere in atto **misure tecniche e organizzative adeguate** per garantire che siano trattati, per impostazione predefinita, **solo i dati personali necessari per ogni specifica finalità** del trattamento. Tale obbligo vale per la **quantità** dei dati personali raccolti, la **portata** del trattamento, il **periodo** di conservazione e l'**accessibilità**.

In particolare, per impostazione predefinita, **non** siano resi **accessibili dati** personali a un **numero indefinito** di persone fisiche senza l'intervento della persona fisica.

(Obbligo indicato anche come *data protection by default* o *privacy by default*) — **STUDIARE ART. 25 DEL REGOLAMENTO**

§9 — Principi Applicabili al Trattamento (art. 5 GDPR)

[fonte: PDF pp. 18-20]

I dati personali devono essere:

1. **Liceità, correttezza e trasparenza:** trattati in modo lecito, corretto e trasparente nei confronti dell'interessato.
 2. **Limitazione della finalità:** raccolti per finalità determinate, esplicite e legittime, e successivamente trattati in modo che non sia incompatibile con tali finalità. Un ulteriore trattamento a fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici non è considerato incompatibile con le finalità iniziali.
 3. **Minimizzazione dei dati:** adeguati, pertinenti e limitati a quanto necessario rispetto alle finalità per le quali sono trattati.
 4. **Esattezza:** esatti e, se necessario, aggiornati; devono essere adottate tutte le misure ragionevoli per cancellare o rettificare tempestivamente i dati inesatti rispetto alle finalità per le quali sono trattati.
 5. **Limitazione della conservazione:** conservati in una forma che consenta l'identificazione degli interessati per un arco di tempo non superiore al conseguimento delle finalità per le quali sono trattati. Periodi più lunghi sono possibili solo a fini di archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici.
 6. **Integrità e riservatezza:** trattati in maniera da garantire un'adeguata sicurezza dei dati personali, compresa la protezione da trattamenti non autorizzati o illeciti e dalla perdita, dalla distruzione o dal danno accidentali.
 7. **Responsabilizzazione** (*accountability*): il titolare del trattamento è competente per il rispetto di questi principi e deve essere in grado di **comprovarlo, dimostrarlo**.
-

§10 — Liceità del Trattamento — Basi Giuridiche (art. 6 GDPR)

[fonte: PDF pp. 21-22]

Il trattamento è **lecito solo se** e nella misura in cui ricorre **almeno una** delle seguenti condizioni (**basi giuridiche del trattamento**):

1. l'interessato ha espresso il **consenso** al trattamento dei propri dati personali per una o più specifiche finalità;
 2. il trattamento è **necessario all'esecuzione di un contratto** di cui l'interessato è parte o all'esecuzione di **misure precontrattuali** adottate su richiesta dello stesso;
 3. il trattamento è **necessario per adempiere un obbligo legale** al quale è soggetto il titolare del trattamento;
 4. il trattamento è **necessario per la salvaguardia degli interessi vitali** dell'interessato o di un'altra persona fisica;
 5. il trattamento è necessario per l'esecuzione di un **compito di interesse pubblico** o **connesso all'esercizio di pubblici poteri** di cui è investito il titolare del trattamento;
 6. il trattamento è **necessario per il perseguimento del legittimo interesse** del titolare del trattamento o di terzi, a condizione che non prevalgano gli interessi o i diritti e le libertà fondamentali dell'interessato che richiedono la protezione dei dati personali, in particolare se l'interessato è un minore. [la regola 6 non si applica al trattamento di dati effettuato dalle autorità pubbliche nell'esecuzione dei loro compiti]
-

§11 — Condizioni per il Consenso

[fonte: PDF pp. 23-24]

Se il trattamento è basato sul **consenso**, il titolare del trattamento deve essere in grado di **dimostrare** che l'interessato ha prestato il proprio consenso al trattamento dei propri dati personali.

Se il consenso è prestato nel contesto di una dichiarazione scritta che riguarda anche altre questioni, la richiesta di consenso è presentata in modo **chiaramente distinguibile** dalle altre materie, in forma **comprensibile e facilmente accessibile**, utilizzando un **linguaggio semplice e chiaro**. Nessuna parte di una tale dichiarazione che costituisca una violazione del Regolamento è vincolante.

L'interessato ha il **diritto di revocare** il proprio consenso **in qualsiasi momento**. La revoca del consenso **non pregiudica la liceità del trattamento basata sul consenso prima della revoca**. Prima di esprimere il proprio consenso, l'interessato è informato di ciò. Il consenso è **revocato con la stessa facilità con cui è accordato**.

Nel valutare se il consenso sia stato liberamente prestato, si tiene nella massima considerazione l'eventualità che l'**esecuzione di un contratto**, compresa la **prestazione di un servizio**, sia **condizionata** alla prestazione del **consenso** al trattamento di dati personali **non necessario** all'esecuzione di tale contratto.

Consenso dei minori

[fonte: PDF p. 25]

Per l'offerta diretta di servizi della società dell'informazione ai minori, il trattamento è lecito ove il minore abbia almeno **16 anni**. Per età inferiore, il consenso deve essere prestato o autorizzato dal **titolare della responsabilità genitoriale**. Gli Stati Membri possono stabilire un'età inferiore purché **non inferiore ai 13 anni**. In **Italia** è fissata a **14 anni** (art. 2-*quinqüies* Codice Privacy).

§12 — Trattamento di Categorie Particolari di Dati Personali (art. 9 GDPR)

[fonte: PDF pp. 26-30]

È **vietato** trattare dati personali che rivelino l'**origine razziale o etnica**, le **opinioni politiche**, le **convinzioni religiose o filosofiche**, l'**appartenenza sindacale**, dati **genetici**, dati **biometrici** intesi a identificare in modo univoco una persona fisica, dati relativi alla **salute**, dati relativi alla **vita sessuale** o all'**orientamento sessuale** della persona.

Si tratta dei dati comunemente denominati “**sensibili**”.

Eccezioni (il divieto non vale nei seguenti casi):

A. l'interessato ha prestato il proprio **consenso esplicito** per una o più **finalità specifiche**; B. il trattamento è necessario per assolvere gli **obblighi** ed esercitare i **diritti** specifici del titolare o dell'interessato in materia di **diritto del lavoro** e della **sicurezza e protezione sociale**, nella misura autorizzata dal diritto UE o degli Stati Membri o da un **contratto collettivo**; C. il trattamento è necessario per tutelare un **interesse vitale** dell'interessato o di un'altra persona fisica qualora l'interessato si trovi nell'**incapacità fisica o giuridica** di prestare il proprio consenso; D. il trattamento è effettuato da una **fondazione, associazione** o altro organismo **senza scopo**

di lucro che persegua finalità politiche, filosofiche, religiose o sindacali, con adeguate garanzie, riguardante unicamente i propri membri/ex membri/persone con regolari contatti, a condizione che i dati non siano comunicati all'esterno senza consenso; E. il trattamento riguarda **dati personali resi manifestamente pubblici dall'interessato**; F. il trattamento è necessario per **accertare, esercitare o difendere un diritto in sede giudiziaria** o ogniqualvolta le autorità giurisdizionali esercitano le loro funzioni giurisdizionali; G. il trattamento è necessario per motivi di **interesse pubblico rilevante** sulla base del diritto UE o nazionale; H. il trattamento è necessario per finalità di **medicina preventiva o del lavoro, valutazione della capacità lavorativa, diagnosi, assistenza o terapia sanitaria o sociale** o gestione dei sistemi e servizi sanitari o sociali; I. il trattamento è necessario per motivi di **interesse pubblico nel settore della sanità pubblica**; J. il trattamento è necessario a fini di **archiviazione nel pubblico interesse, di ricerca scientifica o storica o a fini statistici**.

Gli Stati Membri possono mantenere o introdurre **ulteriori condizioni**, comprese limitazioni, con riguardo al trattamento di dati **genetici**, dati **biometrici** o dati relativi alla **salute**.

§13 — Informativa (artt. 12, 13 e 14 GDPR)

[fonte: PDF pp. 31-32]

PRIMA di raccogliere i dati deve essere fornita un'informativa con un contenuto minimo (leggere gli artt. 12, 13 e 14 del Regolamento):

- l'identità e i dati di contatto del **titolare** del trattamento;
- i dati di contatto del responsabile della protezione dei dati (**DPO** o **RPD**) se nominato;
- le **finalità** del trattamento e la **base giuridica** del trattamento;
- eventuali **destinatari** o eventuali **categorie** di destinatari dei dati personali;
- l'**intenzione** del titolare di trasferire dati personali a un **paese terzo** o a un'organizzazione internazionale;
- il **periodo di conservazione** dei dati personali o, se non possibile, i **criteri** utilizzati per determinare tale periodo;
- i **diritti** dell'interessato (accesso, rettifica, cancellazione, limitazione, opposizione, portabilità);
- il diritto di **revocare** il consenso in qualsiasi momento senza pregiudicare la liceità del trattamento basata sul consenso prestato prima della revoca;
- il diritto di proporre **reclamo** a un'autorità di controllo;
- se la comunicazione di dati personali è un **obbligo legale o contrattuale** oppure un **requisito necessario** per la conclusione di un contratto, e le possibili conseguenze della mancata comunicazione;
- l'esistenza di un **processo decisionale automatizzato**, compresa la **profilazione**.

§14 — Diritti dell'Interessato (artt. 15-22 GDPR)

[fonte: PDF p. 33]

Leggere attentamente gli artt. da 15 a 22 del Regolamento.

- Diritto di **accesso** (art. 15): l'interessato ha il diritto di ottenere la conferma che sia o meno in corso un trattamento di dati personali che lo riguardano e, in tal caso, di ottenere l'accesso a tali dati.
- Diritto di **rettifica** (art. 16): l'interessato ha il diritto di ottenere dal titolare la rettifica dei dati personali inesatti che lo riguardano.
- Diritto di **integrazione** (art. 16): l'interessato ha il diritto di ottenere l'integrazione dei dati personali incompleti.
- Diritto di **cancellazione** / c.d. **diritto all'oblio** (art. 17): l'interessato ha il diritto di ottenere dal titolare la cancellazione dei dati personali che lo riguardano.
- Diritto di **limitazione** del trattamento (art. 18): l'interessato ha il diritto di ottenere dal titolare la limitazione del trattamento.
- Diritto alla **portabilità** dei dati (art. 20): l'interessato ha il diritto di ricevere in un formato strutturato, di uso comune e leggibile da dispositivo automatico i dati personali che lo riguardano.
- Diritto di **opposizione** (art. 21): l'interessato ha il diritto di opporsi in qualsiasi momento al trattamento dei dati personali che lo riguardano.

§15 — Registri delle Attività di Trattamento (art. 30 GDPR)

[fonte: PDF pp. 34-36]

Chi deve tenerli? - Tutte le imprese od organizzazioni con **più di 250 dipendenti**. - Le imprese od organizzazioni con **meno di 250 dipendenti se**: il trattamento che esse effettuano possa presentare un **rischio** per i diritti e le libertà dell'interessato, il trattamento **non sia occasionale**, o includa il trattamento di **categorie particolari di dati**.

Come vanno tenuti? In **forma scritta**, anche in **formato elettronico**. Devono essere messi a disposizione in caso di controllo.

Contenuto del Registro del Titolare: nome e dati di contatto del titolare e del DPO, finalità del trattamento, categorie di interessati e di dati personali, categorie di destinatari, trasferimenti verso paesi terzi, termini ultimi per la cancellazione, descrizione generale delle misure di sicurezza.

Contenuto del Registro del Responsabile: nome e dati di contatto del responsabile (e di ogni titolare per cui agisce) e del DPO, categorie dei trattamenti effettuati per conto di ogni titolare, trasferimenti verso paesi terzi, descrizione generale delle misure di sicurezza tecniche e organizzative.

§16 — Misure di Sicurezza (art. 32 GDPR)

[fonte: PDF pp. 37-40]

Tenuto conto della natura, dell'ambito di applicazione, del contesto e delle finalità del trattamento, nonché dei rischi aventi probabilità e gravità diverse per i diritti e le libertà delle persone fisiche, il **titolare** del trattamento deve attuare **misure tecniche e organizzative adeguate** per garantire, ed essere in grado di dimostrare, che il trattamento è effettuato conformemente al Regolamento. Le misure sono riesaminate e aggiornate se necessario. — **STUDIARE ART. 24 DEL REGOLAMENTO**

Nel valutare l'adeguato livello di sicurezza, si tiene conto in special modo dei **rischi** presentati dal trattamento che derivano in particolare da: distruzione, perdita, modifica, divulgazione non autorizzata o accesso in modo accidentale o illegale a dati personali trattati.

Esempi di misure di sicurezza: - **Pseudonimizzazione** e **cifratura** dei dati personali; - Capacità di assicurare su base permanente la **riservatezza**, l'**integrità**, la **disponibilità** e la **resilienza** dei sistemi e dei servizi di trattamento; - Capacità di **ripristinare tempestivamente** la disponibilità e l'accesso dei dati personali in caso di **incidente fisico o tecnico**; - Procedura per **testare, verificare e valutare regolarmente** l'efficacia delle misure tecniche e organizzative al fine di **garantire la sicurezza** del trattamento.

L'adesione a un codice di condotta approvato o a un meccanismo di certificazione approvato può essere utilizzata come elemento per dimostrare la conformità alla normativa.

§17 — Violazione dei Dati (Data Breach) (artt. 33-34 GDPR)

[fonte: PDF pp. 41-42]

Notifica al Garante (art. 33)

In caso di violazione dei dati personali, il **titolare deve notificare** la violazione al **Garante privacy** senza ingiustificato ritardo e, ove possibile, entro **72 ore** dal momento in cui ne è venuto a conoscenza, **a meno che sia improbabile che la violazione dei dati personali presenti un rischio per i diritti e le libertà delle persone fisiche**.

Se la notifica non avviene entro 72 ore, è corredata dei **motivi del ritardo**.

Il **responsabile** del trattamento deve **informare il titolare** del trattamento **senza ingiustificato ritardo** dopo essere venuto a conoscenza della violazione.

Comunicazione all'Interessato (art. 34)

Quando la violazione dei dati personali **può presentare un rischio elevato** per i diritti e le libertà delle persone fisiche, il titolare del trattamento deve **comunicare la violazione all'interessato** senza ingiustificato ritardo.

La comunicazione **non è richiesta** se: - il titolare ha attuato misure di protezione tecniche e organizzative adeguate e tali misure erano state applicate ai dati oggetto della violazione (es. **cifratura**); - il titolare ha successivamente adottato misure atte a **scongiurare** il sopraggiungere di un rischio elevato; - la comunicazione richiederebbe **sforzi sproporzionati**: in tal caso si deve procedere a una **comunicazione pubblica** o a una misura simile, tramite la quale gli interessati sono informati con analoga efficacia.

§18 — Valutazione d'Impatto sulla Protezione dei Dati — DPIA (art. 35 GDPR)

[fonte: PDF pp. 43-45]

(*DPIA = Data Protection Impact Assessment*)

Quando un tipo di trattamento, allorché prevede in particolare l'uso di **nuove tecnologie**, considerati la natura, l'oggetto, il contesto e le finalità del trattamento, **può presentare un rischio elevato** per i diritti e le libertà delle persone fisiche, il **titolare** del trattamento deve effettuare, **prima** di procedere al trattamento, una **valutazione dell'impatto dei trattamenti previsti sulla protezione dei dati personali**.

Una singola valutazione può esaminare un **insieme di trattamenti simili** che presentano rischi elevati analoghi.

Quando occorre la DPIA (in particolare): - **valutazione sistematica** e globale di aspetti personali relativi a persone fisiche, basata su un trattamento automatizzato, compresa la **profilazione**, e sulla quale si fondano decisioni che hanno **effetti giuridici** o incidono in modo significativo su dette persone fisiche; - il trattamento, su larga scala, di **categorie particolari di dati personali** o di dati relativi a condanne penali e a reati; - la **sorveglianza sistematica** su larga scala di una zona accessibile al **pubblico**.

Contenuto della DPIA: - **descrizione** sistematica dei trattamenti previsti e delle finalità del trattamento; - valutazione della **necessità e proporzionalità** dei trattamenti in relazione alle finalità; - valutazione dei **rischi** per i diritti e le libertà degli interessati; - **misure** previste per affrontare i rischi (garanzie, misure di sicurezza, meccanismi per garantire la protezione dei dati personali e dimostrare la conformità al regolamento).

§19 — Responsabile della Protezione dei Dati — DPO (artt. 37-39 GDPR)

[fonte: PDF pp. 46-49]

Comunemente detto **DPO** (*Data Protection Officer*). Svolge numerosi compiti di **supporto all'applicazione** del Regolamento.

Caratteristiche: - Deve essere persona **esperta** sulla **normativa** e **prassi** della protezione dei dati; - Può essere un **dipendente** del Titolare o del Responsabile del trattamento o un **soggetto esterno** con cui si stipula un contratto di servizi; - **Non** deve essere in **conflitto di interesse**; - **Non** deve ricevere **istruzioni** dal Titolare o dal Responsabile del trattamento; - I suoi **dati** devono essere **pubblicati** e **comunicati al Garante**.

Quando deve essere nominato il DPO (art. 37)? - il trattamento è effettuato da un'**autorità pubblica** o da un organismo pubblico (eccettuate le autorità giurisdizionali); - le **attività principali** del titolare o del responsabile consistono in trattamenti che, per loro natura, ambito e/o finalità, richiedono il **monitoraggio regolare e sistematico degli interessati su larga scala**; - le **attività principali** consistono nel trattamento, su **larga scala**, di **categorie particolari di dati personali** (art. 9) o di dati relativi a condanne penali e a reati.

Un **gruppo imprenditoriale** può nominare un **unico DPO**, a condizione che sia facilmente raggiungibile da ciascuno stabilimento.

Compiti minimi del DPO (art. 39): - **Informare** e fornire **consulenza** al titolare, al responsabile e ai dipendenti sugli obblighi del regolamento; - **Sorvegliare** l'osservanza del Regolamento, di altre norme UE o nazionali sulla protezione dei dati e delle politiche del titolare/responsabile; - Fornire, se richiesto, un **parere** in merito alla **valutazione d'impatto** sulla protezione dei dati e sorvegliarne lo svolgimento; - **Cooperare** con l'autorità di controllo (Garante privacy); - Fungere da **punto di contatto** per l'autorità di controllo.

§20 — Codici di Condotta e Certificazioni (artt. 40-43 GDPR)

[fonte: PDF pp. 50-51]

Codici di condotta: l'elaborazione di codici di condotta può contribuire alla corretta applicazione del Regolamento, in funzione delle specificità dei vari settori di trattamento e delle esigenze specifiche delle micro, piccole e medie imprese. Possono essere elaborati da associazioni e altri organismi rappresentanti le categorie di titolari o responsabili.

Certificazioni: il Regolamento incoraggia l'istituzione di **meccanismi di certificazione** della protezione dei dati nonché di **sigilli** e **marchi di protezione dei dati** allo scopo di dimostrare la **conformità** al regolamento dei trattamenti effettuati dai titolari e dai responsabili del trattamento.

§21 — Trasferimenti di Dati Extra UE (artt. 44 ss. GDPR)

[fonte: PDF pp. 52-56]

Principio generale: il trasferimento di dati extra UE può avvenire soltanto se il titolare e il responsabile del trattamento rispettano le condizioni del Regolamento. Le regole sono applicate al fine di assicurare che il livello di protezione delle persone fisiche garantito dal regolamento **non sia pregiudicato**.

Condizioni ordinarie:

1. **Decisione di adeguatezza:** la Commissione Europea stabilisce che determinati Paesi garantiscono un livello di protezione adeguato — non occorrono autorizzazioni specifiche;
2. **Garanzie adeguate:** manca una decisione di adeguatezza ma il titolare o il responsabile del trattamento forniscono garanzie adeguate, es. **norme vincolanti d'impresa** (norme giuridicamente vincolanti adottate a livello di gruppo di impresa), **clausole contrattuali tipo** adottate dalla Commissione o da un'autorità di controllo.

Deroghe (in mancanza delle condizioni precedenti):

- **consenso dell'interessato**, dopo essere stato informato dei possibili rischi;
- **trasferimento necessario all'esecuzione di un contratto** concluso tra l'interessato e il titolare del trattamento;
- **trasferimento necessario per la conclusione o l'esecuzione di un contratto** stipulato tra il titolare del trattamento e un'altra persona fisica o giuridica;
- **trasferimento necessario** per importanti motivi di **interesse pubblico**;
- trasferimento necessario per accertare, esercitare o difendere un **diritto in sede giudiziaria**;
- trasferimento necessario per tutelare gli **interessi vitali** dell'interessato o di altre persone;
- trasferimento effettuato a partire **da un registro pubblico**.

Trasferimenti UE-USA

Nel tempo le condizioni di liceità dei trasferimenti verso gli USA hanno sperimentato alterne vicende:
- **Safe Harbor** — invalidato nel 2015 dalla Corte di Giustizia Europea (c.d. “**Schrems I**”); -
Privacy Shield — invalidato nel 2020 dalla Corte di Giustizia Europea (c.d. “**Schrems II**”); -

Attualmente: **Data Privacy Framework** — il 10 luglio 2023 la Commissione europea ha adottato la decisione di adeguatezza del quadro normativo sulla privacy dei dati UE-USA. Sulla base di questa decisione, i dati personali possono circolare liberamente dall'UE alle società negli Stati Uniti che partecipano al Data Privacy Framework.

§22 — Sanzioni

[fonte: PDF pp. 57-58]

Sanzioni GDPR (art. 83)

Per alcune violazioni (es. obblighi del titolare o del responsabile del trattamento) sono previste sanzioni amministrative pecuniarie **fino a 10.000.000 EUR**, o per le imprese, **fino al 2% del fatturato mondiale totale annuo** dell'esercizio precedente, **se superiore**.

Per altre violazioni (es. principi di base, diritti degli interessati, trasferimenti extra UE) sono previste sanzioni amministrative pecuniarie **fino a 20.000.000 EUR**, o per le imprese, **fino al 4% del fatturato mondiale totale annuo** dell'esercizio precedente, **se superiore**.

Illeciti penali nel Codice Privacy

- **Trattamento illecito di dati** (art. 167);
 - **Comunicazione e diffusione illecita di dati personali oggetto di trattamento su larga scala** (art. 167-bis);
 - **Acquisizione fraudolenta di dati personali oggetto di trattamento su larga scala** (art. 167-ter);
 - **Falsità nelle dichiarazioni al Garante e interruzione dell'esecuzione dei compiti o dell'esercizio dei poteri del Garante** (art. 168);
 - **Pene accessorie**: pubblicazione della sentenza sul sito internet del Ministero della Giustizia (art. 172 e art. 36 c.p., c. 2,3).
-

§23 — Il Garante per la Protezione dei Dati Personali

[fonte: PDF pp. 60-61]

Il Garante per la protezione dei dati personali è un'**autorità amministrativa indipendente**, organo collegiale composto da **quattro membri eletti dal Parlamento** (2 dalla Camera, 2 dal Senato). Il Collegio rimane in carica per un **mandato di sette anni non rinnovabile**.

Compiti (sintesi): - Verifica l'applicazione della normativa privacy; - Esamina i reclami e le segnalazioni e decide sui ricorsi; - Può vietare il trattamento illecito dei dati e disporne il blocco; - Segnala a Governo e Parlamento l'opportunità di interventi normativi; - Partecipa alla discussione su iniziative normative con audizioni in Parlamento; - Esprime pareri; - Denuncia fatti perseguibili d'ufficio; - Predispose una relazione annuale.

Riferimenti Normativi

Articolo / Norma	Contenuto (come descritto nel PDF)	Rilevanza per il corso
Reg. UE 2016/679, art. 4	Definizioni: dato personale, trattamento, profilazione, pseudonimizzazione, titolare, responsabile, interessato	Fondamento del modulo
Reg. UE 2016/679, art. 5	Principi applicabili al trattamento (7 principi)	Alta — da sapere a memoria
Reg. UE 2016/679, art. 6	Liceità del trattamento — 6 basi giuridiche	Alta — da sapere a memoria
Reg. UE 2016/679, art. 9	Categorie particolari di dati (dati sensibili) — divieto e deroghe A-J	Alta
Reg. UE 2016/679, artt. 12-14	Informativa — contenuto minimo	Alta
Reg. UE 2016/679, artt. 15-22	Diritti dell'interessato	Alta
Reg. UE 2016/679, art. 24	Misure di sicurezza — obblighi del titolare	Alta
Reg. UE 2016/679, art. 25	Privacy by design e by default	Alta — segnalata dalla prof
Reg. UE 2016/679, art. 30	Registri delle attività di trattamento	Media
Reg. UE 2016/679, art. 32	Misure di sicurezza — cosa fare	Alta
Reg. UE 2016/679, artt. 33-34	Notifica e comunicazione violazioni dei dati	Alta
Reg. UE 2016/679, art. 35	DPIA — quando e come	Alta
Reg. UE 2016/679, artt. 37-39	DPO — nomina, caratteristiche, compiti	Alta
Reg. UE 2016/679, art. 44 ss.	Trasferimenti extra UE	Media
Reg. UE 2016/679, art. 83	Sanzioni	Alta
D.Lgs. 196/2003, art. 2- <i>quinquies</i>	Consenso minori: età min. 14 anni in Italia	Media
D.Lgs. 196/2003, art. 2- <i>quaterdecies</i>	Attribuzione funzioni a soggetti designati	Bassa
D.Lgs. 196/2003, artt. 167-168	Illeciti penali	Media

Casi e Scenari

[fonte: PDF — esempi espliciti della professoressa]

Titolare vs Responsabile: Una società che tratta i dati dei propri clienti e dipendenti = **Titolare**. Il consulente del lavoro che elabora le buste paga di quella società usando i dati dei dipendenti = **Responsabile** (tratta per conto del Titolare).

Responsabile del trattamento vs DPO: Non confondere. Il Responsabile è chi tratta dati per

conto del Titolare (data processor). Il DPO è il consulente esperto in normativa privacy, che non deve ricevere istruzioni e non deve essere in conflitto di interesse.

Consenso condizionato al servizio: È vietato condizionare la prestazione di un servizio al consenso per trattamenti non necessari all'esecuzione del contratto. Il consenso così ottenuto non è considerato liberamente prestato.

Minori: WhatsApp ha vietato l'uso dell'app ai minori di 16 anni senza autorizzazione dei genitori.

Trasferimenti UE-USA: Safe Harbor (invalidato 2015 — Schrems I) → Privacy Shield (invalidato 2020 — Schrems II) → Data Privacy Framework (valido dal 10 luglio 2023).

Sanzioni: Google è stata multata dal Garante francese (CNIL) per 50 milioni EUR (2% fatturato) per violazione dei principi di trasparenza e basi giuridiche del consenso.

Domande di Autoverifica

(Tipo esame — rispondere in forma discorsiva prima di scrivere gli appunti grezzi)

1. Qual è la differenza tra dato personale “comune” e dato “sensibile” (categoria particolare)? Fai tre esempi per ciascuna categoria e spiega perché il trattamento dei dati sensibili è soggetto a disciplina più restrittiva.
2. Un'azienda vuole profilare i propri clienti per finalità di marketing. Indica quali basi giuridiche del trattamento potrebbe invocare (art. 6 GDPR) e spiega perché alcune potrebbero essere più problematiche di altre. Cosa cambia se vengono trattati anche dati relativi alla salute?
3. Descrivi la differenza tra “privacy by design” e “privacy by default” (art. 25 GDPR), con un esempio concreto per ciascuno. Quando devono essere attuate queste misure?
4. Un'azienda subisce un attacco hacker che comporta la divulgazione non autorizzata dei dati personali di 500 clienti. Descrivi la procedura di gestione della violazione: chi deve fare cosa, entro quali termini, e in quali casi la comunicazione all'interessato può essere omessa.
5. Quando un'organizzazione è obbligata a nominare un DPO? Quali caratteristiche deve avere e quali sono i suoi compiti minimi secondo il GDPR? Perché il DPO non deve ricevere istruzioni dal Titolare?

Riepilogo

- Il **GDPR** (Reg. UE 2016/679) si applica direttamente in tutta l'UE dal 25 maggio 2018 e tutela i diritti fondamentali delle persone fisiche in materia di trattamento dei dati personali; il **Codice Privacy** (D.Lgs. 196/2003) è lo strumento nazionale di adeguamento.
- Il trattamento è lecito solo se fondato su **almeno una delle sei basi giuridiche** dell'art. 6 GDPR; per i dati sensibili (art. 9) vige un **divieto generale** con deroghe tassative che richiedono in genere il **consenso esplicito** o altra condizione qualificata.
- Il **principio di responsabilizzazione** (*accountability*) impone al Titolare non solo di rispettare i principi dell'art. 5 GDPR (liceità, minimizzazione, esattezza, limitazione della conservazione, integrità/riservatezza) ma di **saperlo dimostrare**, attraverso misure di sicurezza adeguate, registri delle attività, DPIA ove necessaria e, in certi casi, nomina del DPO.

Collegati

- [[appunti_moduloD8]]
- [[appunti_moduloD8_privacy_gdpr]]
- [[speedreview_D08_privacy_gdpr]]

Hub: [[master_map_studio]] · [[glossario_diritto]] · [[concept_maps]]